

Informations générales

Suivi des patients et rappels médicaux - HealthMed

Saisie : Lucas BENADY, Ugo Pujol, Enzo Said

Évaluation : DPO X-corp

Validation : Direction HealthMed / RSSI X-corp

Statut : Validation simple (100%)

Contexte

Vue d'ensemble

Données, processus et supports

Principes fondamentaux

Proportionnalité et nécessité

Mesures protectrices des droits

Risques

Mesures existantes ou prévues

Accès illégitime à des données

Modification non désirées de données

Disparition de données

Vue d'ensemble des risques

Validation

Cartographie des risques

Plan d'action

Avis du DPD et des personnes concernées

Quel est le traitement qui fait l'objet de l'étude ?

Plateforme de gestion et de suivi des dossiers patients pour la société HealthMed, opérée via les outils DataManage et AutoMail développés par X-corp.

Le traitement permet d'assurer le suivi des soins, l'historique des prescriptions médicales, les rappels automatiques de rendez-vous et l'envoi de conseils de santé personnalisés. Il concerne une volumétrie d'environ 500 000 patients en France et traite des données sensibles au sens de l'article 9 du RGPD (données de santé).

Quelles sont les responsabilités liées au traitement ?

Responsable de traitement (RT) : **HealthMed (définit les finalités médicales et collecte le consentement des patients).**

Sous-traitant principal : **X-corp (fournit la solution logicielle DataManage/AutoMail, le paramétrage et la maintenance applicative).**

Sous-traitant ultérieur : **CloudSecure (fournisseur de l'infrastructure d'hébergement et du stockage cloud).**

Gouvernance : **Suivi par le DPO de X-corp en coordination avec le DPO de HealthMed.**

Quels sont les référentiels applicables ?

Règlement Général sur la Protection des Données (RGPD) : **Articles 6 (licéité), 9 (traitement des données sensibles de santé), 28 (obligations de sous-traitance), 32 (sécurité) et 35 (obligation d'AIPD/DPIA).**

Code de la santé publique (Art. L.1111-8) : **Obligation d'hébergement des données de santé sur une infrastructure certifiée HDS (Hébergeur de Données de Santé) pour CloudSecure.**

Référentiel CNIL / ANSSI : **Mesures de sécurité minimales (chiffrement AES-256 repos/transit, authentification multi-facteurs 2FA, cloisonnement des accès RBAC et journalisation des événements).**

Évaluation : Acceptable

Contexte

Données, processus et supports

Quelles sont les données traitées ?

Les données traitées regroupent l'identité et les contacts des 500 000 patients de HealthMed (nom, prénom, adresse postale, mail, numéro de téléphone) ainsi que des données de santé sensibles au sens de l'article 9 du RGPD (historique médical, ordonnances, prescriptions actives et dates de rendez-vous). Les données sont accessibles par le personnel médical autorisé de HealthMed, par notre équipe technique pour la maintenance et par notre hébergeur CloudSecure. La durée de conservation est fixée à 10 ans après la fin du traitement médical.

Comment le cycle de vie des données se déroule-t-il (description fonctionnelle) ?

Les informations sont d'abord saisies par les médecins ou les patients sur la plateforme HealthMed. Ensuite, elles sont transmises de manière sécurisée vers notre application DataManage puis stockées sur l'infrastructure CloudSecure. Notre module AutoMail utilise ces données pour envoyer automatiquement les rappels de rendez-vous et les alertes d'ordonnances par mail ou SMS. Enfin, les données sont conservées pendant 10 ans puis automatiquement supprimées ou anonymisées de manière définitive à l'échéance.

Quels sont les supports des données ?

Le traitement utilise nos applications internes DataManage et AutoMail développées par X-corp. Les serveurs et bases de données sont hébergés chez CloudSecure avec une certification HDS et du chiffrement AES-256. Les échanges réseau passent par des connexions HTTPS et TLS 1.3 sécurisées. Les accès admin se font depuis les PC portables professionnels de l'équipe avec double authentification 2FA et droits RBAC. Il n'y a aucun document papier utilisé.

Évaluation : Acceptable

Principes fondamentaux

Proportionnalité et nécessité

Les finalités du traitement sont-elles déterminées, explicites et légitimes ?

Oui, les objectifs sont clairs et limites au domaine medical : assurer le suivi des traitements des patients, envoyer des rappels automatiques pour les consultations et transmettre des conseils de sante adaptes. Il n y a aucun detournement des donnees vers des objectifs publicitaires ou commerciaux (pas de transfert vers AdBoost).

Évaluation : Acceptable

Quel(s) est(sont) les fondement(s) qui rend(ent) votre traitement licite ?

Le traitement repose sur le consentement explicite prealable du patient conforme aux articles 6.1.a et 9.2.a du RGPD pour les donnees de sante. Le consentement est recueilli a la creation du compte HealthMed avec une case a cocher dediee et non pre-cochee.

Évaluation : Acceptable

Les données collectées sont-elles adéquates, pertinentes et limitées à ce qui est nécessaire au regard des finalités pour lesquelles elles sont traitées (minimisation des données) ?

Oui, seules les informations strictement utiles aux soins et rappels sont collectees : identite et contact pour les notifications, ordonnances et historique medical pour le suivi. Aucune information superflue (comme les donnees bancaires ou la geolocalisation en temps reel) n est demandee.

Évaluation : Acceptable

Les données sont-elles exactes et tenues à jour ?

Les informations sont directement renseignees et validees par les soignants et les patients lors des consultations ou sur leur compte en ligne. En cas d erreur ou de changement d adresse ou de prescription, la mise a jour est immediate dans la base DataManage. Des controles de format automatiques sont aussi integres sur l interface pour eviter les erreurs de frappe (sur les numeros de portable, emails et formats d ordonnances).

Évaluation : Acceptable

Quelle est la durée de conservation des données ?

La duree est fixee a 10 ans apres la fin de la prise en charge medicale du patient. Ce delai est justifie par la continuite des soins, le suivi historique des pathologies et les delais de responsabilite dans le domaine medical. Passe ce delai de 10 ans, un script de purge supprime definitivement les donnees ou les anonymise de facon irreversible.

Évaluation : Acceptable

Comment les personnes concernées sont-elles informées à propos du traitement ?

Une mention d'information claire et complète est affichée lors de la première connexion ou de la création du compte sur le portail HealthMed. Elle précise les finalités du traitement, le rôle de sous-traitant de X-corp, la durée de conservation de 10 ans, le caractère sensible des données de santé et les coordonnées du DPO pour exercer ses droits.

Évaluation : Acceptable

Si applicable, comment le consentement des personnes concernées est-il obtenu ?

Le consentement explicite est recueilli directement à l'inscription via une case à cocher obligatoire et non cochée par défaut (opt-in strict), séparée des conditions générales d'utilisation. La date, l'heure et la version de la mention acceptée sont tracées et enregistrées en base de données.

Évaluation : Acceptable

Comment les personnes concernées peuvent-elles exercer leurs droit d'accès et droit à la portabilité ?

Les patients ont un accès direct à l'ensemble de leur dossier et de leurs ordonnances depuis leur profil en ligne. Ils disposent d'un bouton d'export pour télécharger l'intégralité de leurs données sous un format structuré et lisible par machine (JSON ou CSV).

Évaluation : Acceptable

Comment les personnes concernées peuvent-elles exercer leurs droit de rectification et droit à l'effacement (droit à l'oubli) ?

Les coordonnées personnelles peuvent être modifiées directement par le patient depuis l'interface. Pour les données médicales ou la suppression totale du compte, une demande peut être soumise via un formulaire en ligne ou par mail au support. Les données sont supprimées des bases et des sauvegardes sous 30 jours maximum.

Évaluation : Acceptable

Comment les personnes concernées peuvent-elles exercer leurs droit de limitation et droit d'opposition ?

Les patients peuvent à tout moment désactiver les alertes et notifications automatiques AutoMail depuis leurs paramètres. Ils peuvent aussi faire une demande de gel temporaire du traitement de leur dossier en cas de contestation sur une donnée ou un suivi.

Évaluation : Acceptable

Les obligations des sous-traitants sont-elles clairement définies et contractualisées ?

Oui, un contrat DPA (Article 28 du RGPD) est signé entre HealthMed et X-corp, ainsi qu'entre X-corp et CloudSecure. Le contrat formalise les mesures de sécurité obligatoires, l'hébergement certifié HDS, la confidentialité stricte et la notification sous 24h en cas d'incident ou de faille de sécurité.

Évaluation : Acceptable

En cas de transfert de données en dehors de l'Union européenne, les données sont-elles protégées de manière équivalente ?

Il n'y a aucun transfert de données personnelles en dehors de l'Union européenne. Toutes les bases de données et serveurs de CloudSecure sont physiquement localisés en France et dans l'UE conformément aux règles HDS et à la politique de souveraineté des données de santé.

Risques

Mesures existantes ou prévues

Chiffrement et pseudonymisation des données

Chiffrement des bases de données et des sauvegardes avec l'algorithme AES-256 chez CloudSecure. Chiffrement des flux en transit en TLS 1.3. Séparation logique entre la table d'identité et les données médicales via un identifiant pseudonymisé.

Évaluation : Acceptable

Contrôle des accès et authentification forte

Mise en place d'une double authentification 2FA obligatoire pour l'ensemble des utilisateurs et administrateurs. Gestion des permissions selon le principe du moindre privilège via une politique RBAC (Role-Based Access Control).

Évaluation : Acceptable

Journalisation et traçabilité

Enregistrement automatique et immuable de tous les accès, consultations, modifications et suppressions sur les dossiers patients. Conservation des logs de sécurité pendant 1 an pour audit et détection d'intrusions.

Évaluation : Acceptable

Hébergement sécurisé HDS et sauvegardes

Infrastructure hébergée chez CloudSecure certifiée Hébergeur de Données de Santé (HDS) en France/UE. Sauvegardes quotidiennes chiffrées et redondance sur plusieurs sites pour garantir la disponibilité.

Évaluation : Acceptable

Risques

Accès illégitime à des données

Quels pourraient être les principaux impacts sur les personnes concernées si le risque se produisait ?

Erreur médicale ou mauvais dosage de médicament pouvant directement mettre la vie du patient en danger.

Quelles sont les principales menaces qui pourraient permettre la réalisation du risque ?

Injection SQL sur DataManage, attaque malware ou fausse manipulation d'un compte administrateur.

Quelles sources de risques pourraient-elles en être à l'origine ?

Attaquants externes cherchant à saboter la base ou erreur humaine interne lors d'une maintenance.

Quelles sont les mesures initiales, parmi celles identifiées, qui contribuent à traiter le risque ?

Contrôle des accès et authentification forte, Hébergement sécurisé HDS et sauvegardes, Journalisation et traçabilité

Comment estimez-vous la gravité du risque, notamment en fonction des impacts potentiels et des mesures prévues ?

Maximale, il s'agit d'un risque bien réel et à ne pas négliger.

Comment estimez-vous la vraisemblance du risque, notamment au regard des menaces, des sources de risques et des mesures prévues ?

Négligeable, il s'agit d'un risque bien réel et à ne pas négliger.

Évaluation : Acceptable

Risques

Modification non désirées de données

Quels pourraient être les principaux impacts sur les personnes concernées si le risque se produisait ?

Erreur médicale ou mauvais dosage de médicament pouvant directement mettre la vie du patient en danger.

Quelles sont les principales menaces qui pourraient permettre la réalisation du risque ?

Injection SQL sur DataManage, attaque malware ou fausse manipulation d'un compte administrateur.

Quelles sources de risques pourraient-elles en être à l'origine ?

Attaquants externes cherchant à saboter la base ou erreur humaine interne lors d'une maintenance.

Quelles sont les mesures, parmi celles identifiées, qui contribuent à traiter le risque ?

Contrôle des accès et authentification forte, Journalisation et traçabilité, Hébergement sécurisé HDS et sauvegardes

Comment estimez-vous la gravité du risque, notamment en fonction des impacts potentiels et des mesures prévues ?

Maximale, Dans le cas de modifications de donnée, il s'agit d'un risque critique, car un changement de dosage chez un patient pourrait entraîner sa mort.

Comment estimez-vous la vraisemblance du risque, notamment au regard des menaces, des sources de risques et des mesures prévues ?

Maximale, Dans le cas de modifications de donnée, il s'agit d'un risque critique, car un changement de dosage chez un patient pourrait entraîner sa mort.

Évaluation : Acceptable

Risques

Disparition de données

Quels pourraient être les principaux impacts sur les personnes concernées si le risque se produisait ?

Erreur médicale ou mauvais dosage de médicament pouvant directement mettre la vie du patient en danger.

Quelles sont les principales menaces qui pourraient permettre la réalisation du risque ?

Injection SQL sur DataManage, attaque malware ou fausse manipulation d'un compte administrateur.

Quelles sources de risques pourraient-elles en être à l'origine ?

Attaquants externes cherchant à saboter la base ou erreur humaine interne lors d'une maintenance.

Quelles sont les mesures, parmi celles identifiées, qui contribuent à traiter le risque ?

Contrôle des accès et authentification forte

Comment estimez-vous la gravité du risque, notamment en fonction des impacts potentiels et des mesures prévues ?

Maximale, Le risque reste énorme car la perte de donnée pourrait avoir de lourde conséquence sur le suivi d'un traitement d'un patient.

Comment estimez-vous la vraisemblance du risque, notamment au regard des menaces, des sources de risques et des mesures prévues ?

Importante, Le risque reste énorme car la perte de donnée pourrait avoir de lourde conséquence sur le suivi d'un traitement d'un patient.

Évaluation : Acceptable

Impacts potentiels

Erreur médicale ou mauvais

Menaces

Injection SQL sur DataMan

Sources

Attaquants externes chercha

Mesures

Contrôle des acces et authe

Hebergement securise HDS

Journalisation et tracabilite

Accès illégitime à des données

Gravité : Maximale

Vraisemblance : Négligeable

Modification non désirées de d

Gravité : Maximale

Vraisemblance : Maximale

Disparition de données

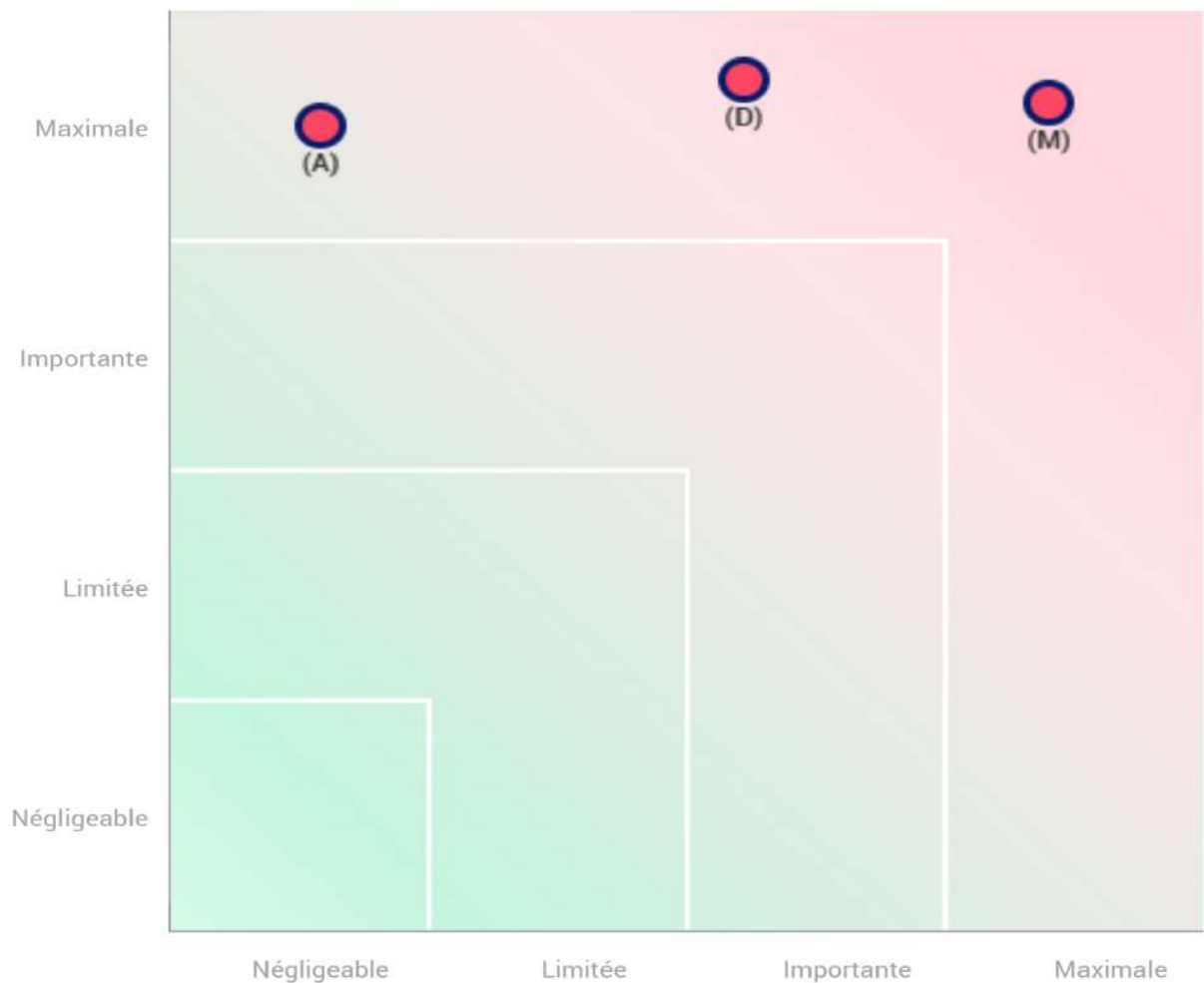
Gravité : Maximale

Vraisemblance : Importante

Validation

Cartographie des risques

Gravité du risque



- Mesures prévues ou existantes
- Avec les mesures correctives mises en oeuvre
- (A)ccès illégitime à des données
- (M)odification non désirée de données
- (D)isparition de données

Vraisemblance du risque

Vue d'ensemble

Principes fondamentaux

Finalités		
Fondement		
Données adéquates		
Données exactes		
Durée de conservation		
Information des personnes		
Recueil du consentement		
Droit d'accès et à la portabilité		
Droit de rectification et d'effacement		
Droit de limitation et d'opposition		
Sous-traitance		
Transferts		

Mesures existantes ou prévues

		Chiffrement et pseudonymisation des données
		Contrôle des accès et authentification forte
		Journalisation et tracabilité
		Hebergement sécurisé HDS et sauvegardes

Risques

		Accès illégitime à des données
		Modification non désirée de données
		Disparition de données

Mesures Améliorables

Mesures Acceptables

Validation

Avis du DPD et des personnes concernées

Nom du DPD

Les nouveaux

Statut du DPD

Le traitement pourrait être mis en oeuvre.

Opinion du DPD

Car la criticité des informations était extrêmement élevée, des mesures sont nécessaires pour pouvoir assurer leur protection.

Recherche de l'avis des personnes concernées

L'avis des personnes concernées n'a pas été demandé.

Raison pour laquelle l'avis des personnes concernées n'a pas été demandé

Il ne devrait pas être nécessaire pour les patients de prendre en charge la protection de leurs données.